

LAB 11 - VULNERABILITY ASSESSMENT: OPENVAS/GVM

Full and Fast Scan - Metasploitable2 | GVM 25.04.0 | 95,089 NVTs | 140 Unique Findings

CySA+ Home Lab Portfolio | Alejandro W. Orellana | June 30, 2026

1. Lab Overview

This lab demonstrates enterprise-grade vulnerability assessment using OpenVAS/GVM (Greenbone Vulnerability Management). GVM 25.04.0 was installed from scratch, configured with the full Emerging Threats NVT feed (95,089 vulnerability tests), and a Full and Fast scan executed against Metasploitable2. The scan identified 140 unique findings across 11 Critical, 8 High, 33 Medium, 6 Low, and 82 Log entries before stopping at 98% due to VM resource constraints.

Field	Detail
Tool	GVM 25.04.0 / OpenVAS 23.30.1 / ospd-openvas 22.10.0
Target	Metasploitable2 - 192.168.40.3
Scan Config	Full and fast - 4 concurrent NVTs per host
NVT Database	95,089 NVTs (Emerging Threats Open feed)
Scan Status	Stopped at 98% - ospd-openvas socket crash (VM RAM exhaustion)
Total Unique Findings	140 (11 Critical, 8 High, 33 Medium, 6 Low, 82 Log)
Highest Severity	10.0 (Critical) - 6 findings including OS EOL, Backdoor, rlogin passwordless login
Active Exploits Confirmed	Ghostcat file read, LFI passwd read, VNC brute force, MySQL/PostgreSQL default creds

2. Findings Summary by Severity

Severity	Count	CVSS	Notable Findings
CRITICAL	11	9.0-10.0	OS EOL, Ingreslock backdoor, rlogin passwordless, TWiki RCE, dRuby RCE, MySQL/PostgreSQL default creds, Ghostcat, DistCC RCE, VNC brute force
HIGH	8	7.0-8.9	rlogin/rsh unencrypted, PHP RCE, Java RMI RCE, FTP default creds, HTTP dangerous methods, SSL OpenSSL MitM
MEDIUM	33	4.0-6.9	Samba 3.x RCE, TWiki XSS/CSRF, SSL/TLS deprecated protocols, cleartext passwords, phpMyAdmin XSS, SSH weak algorithms
LOW	6	0.1-3.9	SSL/TLS POODLE, DHE_EXPORT, SSLv3 CBC, SSH weak MAC, TCP timestamps, ICMP timestamp
LOG	82	0.0	Service detection, OS fingerprinting, inventory, SMB signing, DNS, IRC, RPC, protocol versions
TOTAL	140	-	Unique findings confirmed from 15-page XML export (scan at 98%)

3. Critical Findings - All 11 (CVSS 9.0-10.0)

#	Vulnerability	CVE	CVSS	Port	Attack Vector
---	---------------	-----	------	------	---------------

1	OS End of Life (Ubuntu 8.04)	None	10.0	general/tcp	All future CVEs permanently unpatched
2	Ingreslock Backdoor (port 1524)	None	10.0	1524/tcp	Active backdoor - unauthenticated shell
3	rlogin Passwordless Login	None	10.0	513/tcp	Remote shell with no authentication required
4	rexec Service Running	CVE-1999-0618	10.0	512/tcp	Remote execution - cleartext, no modern auth
5	TWiki RCE Multiple Vulns	CVE-2008-5304/5305	10.0	80/tcp	Command execution via web app
6	dRuby/DRb Multiple RCE	None	10.0	8787/tcp	Remote code execution via distributed Ruby
7	MySQL Default Credentials	CVE-2001-0645	9.8	3306/tcp	DB authentication bypassed with default creds
8	Ghostcat - AJP RCE (Active)	CVE-2020-1938	9.8	8009/tcp	File read CONFIRMED via active exploitation check
9	DistCC RCE	CVE-2004-2687	9.3	3632/tcp	Compiler service allows arbitrary command execution
10	VNC Brute Force Login	None	9.0	5900/tcp	VNC password cracked via brute force
11	PostgreSQL Default Credentials	None	9.0	5432/tcp	DB authentication bypassed with default creds

4. High Severity Findings (CVSS 7.0-8.9)

Vulnerability	CVE	CVSS	Port	Notes
rsh Unencrypted Cleartext Login	CVE-1999-0651	7.5	514/tcp	Legacy remote shell - cleartext credentials
rlogin Service Running	CVE-1999-0651	7.5	513/tcp	Legacy protocol - authentication weaknesses
HTTP Dangerous Methods (PUT/DELETE)	None	7.5	80/tcp	Web server accepts file upload/delete methods
PHP RCE (CVE-2012-1823) - Active	CVE-2012-1823	7.5	80/tcp	PHP-CGI remote code execution - active check
Java RMI RCE Insecure Config	CVE-2011-3556	7.5	1099/tcp	Java RMI registry allows arbitrary class loading
FTP Default Credentials	CVE-1999-0501	7.5	2121/tcp	FTP server accessible with default username/password
EasyPHP Webserver Vulns - Active	None	7.5	80/tcp	Multiple vulnerabilities confirmed by active check
SSL/TLS OpenSSL CCS MitM	CVE-2014-0224	7.4	5432/tcp	ChangeCipherSpec injection - session hijacking

5. Key Finding Deep Dives

Finding 1 — Ingreslock Backdoor (Port 1524, CVSS 10.0)

An active backdoor was detected on port 1524 — a known Metasploitable2 intentional vulnerability but significant for a real environment. Port 1524 is the Ingreslock service port that was repurposed as a backdoor shell. Any connection to this port yields an unauthenticated root shell. This maps to T1505.003 (Web Shell / Backdoor) and represents the most immediately dangerous finding — an attacker needs only a netcat connection.

Finding 2 — Ghostcat CVE-2020-1938 (Port 8009, CVSS 9.8) — Active Check Confirmed

CVE-2020-1938 - Apache Tomcat AJP RCE Vulnerability (Ghostcat)
Port: 8009/tcp | CVSS: 9.8 | Active exploitation check PASSED

OpenVAS successfully read /WEB-INF/web.xml through the AJP connector.
Content-Type: text/html;charset=ISO-8859-1
[Apache Software Foundation license header confirmed in response]

Also confirmed in: Lab 03 Nessus (version-based) - cross-tool validation complete.

Finding 3 — MySQL/PostgreSQL Default Credentials (Ports 3306/5432, CVSS 9.8/9.0)

OpenVAS confirmed that both MySQL (port 3306) and PostgreSQL (port 5432) are accessible using default credentials. This means full database read/write/delete access is available to any attacker without any exploitation of a software vulnerability — just a known username and password. Combined with Lab 08's phpMyAdmin finding, the database is accessible via both command-line and web interface with no credential barrier.

Finding 4 — Cleartext Password Transmission (Port 80, CVSS 4.8)

Password fields transmitted over unencrypted HTTP:
http://192.168.40.3/dvwa/login.php :password
http://192.168.40.3/phpMyAdmin/ :pma_password
http://192.168.40.3/phpMyAdmin/?D=A :pma_password
http://192.168.40.3/tikiwiki/tiki-install.php :pass
http://192.168.40.3/twiki/bin/... :password

6. MITRE ATT&CK; Mapping

Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': 'Technique ID' 'frags': [ParaFrag(__tag__='para', bold=1, fontName='Helvetica-Bold', fontSize=8, greek=0, italic=0, link=[], rise=0, text='Technique ID', textColor=Color(1,1,1,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph	Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': 'Name' 'frags': [ParaFrag(__tag__='para', bold=1, fontName='Helvetica-Bold', fontSize=8, greek=0, italic=0, link=[], rise=0, text='Name', textColor=Color(1,1,1,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph	Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': 'Tactic' 'frags': [ParaFrag(__tag__='para', bold=1, fontName='Helvetica-Bold', fontSize=8, greek=0, italic=0, link=[], rise=0, text='Tactic', textColor=Color(1,1,1,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph	Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': 'OpenVAS Finding' 'frags': [ParaFrag(__tag__='para', bold=1, fontName='Helvetica-Bold', fontSize=8, greek=0, italic=0, link=[], rise=0, text='OpenVAS Finding', textColor=Color(1,1,1,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph
T1190	Exploit Public-Facing Application	Initial Access	Ghostcat (CVE-2020-1938), PHP RCE (CVE-2012-1823), DistCC RCE, TWiki RCE, Java RMI RCE
T1505.003	Server Software: Backdoor	Persistence	Ingreslock backdoor on port 1524 - unauthenticated root shell
T1078	Valid Accounts (Default Creds)	Persistence	MySQL default creds (port 3306), PostgreSQL default creds (port 5432), FTP default creds (port 2121)

T1021	Remote Services	Lateral Movement	rlogin passwordless (513), rsh cleartext (514), rexec (512) - legacy unauthenticated remote access
T1083	File and Directory Discovery	Discovery	LFI at /mutillidae - /etc/passwd traversal confirmed, /doc directory browsable
T1557	Adversary-in-the-Middle	Credential Access	Cleartext HTTP passwords (5 apps), SSL/TLS OpenSSL CCS MitM, deprecated SSLv2/v3, weak cipher suites
T1562.001	Disable/Modify OS Firewall	Defense Evasion	IP forwarding enabled - host can route traffic between networks
T1110.001	Brute Force: Password Guessing	Credential Access	VNC brute force login confirmed (port 5900), SMTP VRFY/EXPN user enumeration

7. OpenVAS vs Nessus - Tool Comparison (Labs 03 and 11)

Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': 'Dimension' 'frags': [ParaFrag(__tag__='para', bold=1, fontName='Helvetica-Bold', fontSize=8, greek=0, italic=0, link=[], rise=0, text='Dimension', textColor=Color(1,1,1,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph	Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': 'Nessus Essentials (Lab 03)' 'frags': [ParaFrag(__tag__='para', bold=1, fontName='Helvetica-Bold', fontSize=8, greek=0, italic=0, link=[], rise=0, text='Nessus Essentials (Lab 03)', textColor=Color(1,1,1,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph	Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': 'OpenVAS/GVM (Lab 11)' 'frags': [ParaFrag(__tag__='para', bold=1, fontName='Helvetica-Bold', fontSize=8, greek=0, italic=0, link=[], rise=0, text='OpenVAS/GVM (Lab 11)', textColor=Color(1,1,1,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph
License	Commercial (free tier - 16 IP limit)	Open source (no IP limit)
NVT Count	~170,000+ plugins	95,089 NVTs (Emerging Threats Open)
Critical findings	9 Critical on Metasploitable2	11 Critical (140 unique total at 98%)
Active checks	Version-based + some active	Ghostcat file read, LFI, VNC brute force, default cred confirmation
CVE-2020-1938	Detected (version-based)	Detected AND actively confirmed - file read proven
Unique findings	8 prioritized findings documented	140 unique findings across all severities
Scan speed	Faster - optimized commercial engine	Slower - resource-intensive, crashed at 98%
Enterprise use	Tenable - industry standard	Common with open-source/budget-constrained orgs

Key Takeaway: The full 140-finding scan reveals a complete attack chain against Metasploitable2: unauthenticated shell via Ingreslock backdoor (port 1524), RCE via six separate critical vulnerabilities, full database access via default credentials on both MySQL and PostgreSQL, legacy remote access via rlogin/rsh/rexec, and persistent credential exposure via cleartext HTTP across five web applications. This host represents a total compromise scenario from multiple independent attack vectors simultaneously.

8. Scanner Crash Root Cause Analysis

Root cause from /var/log/gvm/gvmd.log:

WARNING: Could not connect to Scanner at /run/ospd/ospd-openvas.sock

WARNING: Connection lost with the scanner. Trying again in 1 second.

WARNING: OSP get_scan [UUID]: Failed to find scan '[UUID]'

MESSAGE: Status of task changed to Stopped

Diagnosis: ospd-openvas process crashed mid-scan, dropping its Unix socket.

Root cause: VM RAM exhaustion scanning 95,089 NVTs against 30+ open services.

Production mitigation: Increase RAM, reduce concurrent NVTs, or use dedicated Greenbone Enterprise Appliance.